# KUYFI

## BLACK-BOX SECURITY REPORT

*Before the Breach.*

| | |
|---|---|
| **Contract ID** | CC6Q4V6QVAG5EQTIYX6E34YFWKDLEWMVXSOZRT4DVUE3O24JODIU4YOT |
| **Network** | TESTNET |
| **Report ID** | kyf-20261025T114353Z-f5ab2e63 |
| **Generated At** | 2026-10-25T11:43:53.555Z |
| **Tool Version** | Kuyfi 0.1.0 |
| **Schema Version** | 1.0.0 |

This report is generated by automated black-box fuzzing against a deployed Soroban smart contract. It is not a manual audit and does not constitute a formal security certification.

# 2. Executive Summary

| | |
|---|---|
| **Functions detected** | 6 |
| **UDTs detected** | 3 |
| **Vectors executed** | 51 |
| **Broadcast transactions** | 3 |
| **Transactions with hash** | 3 |
| **Total findings** | 1 |

### Findings by Severity

| | |
|---|---|
| **Critical** | 0 |
| **High** | 1 |
| **Medium** | 0 |
| **Low** | 0 |
| **Info** | 0 |

# 3. Attack Surface

### Target

| | |
|---|---|
| **Contract ID** | CC6Q4V6QVAG5EQTIYX6E34YFWKDLEWMVXSOZRT4DVUE3O24JODIU4YOT |
| **Network** | TESTNET |
| **Bytecode size** | 8034 bytes |

### Functions Detected (6)

- `init(admin: Address, verifier: Address) -> returns value`
- `claim(chest_id: U64, recipient: Address, nullifier: BytesN<32>, proof: Proof) -> returns value`
- `get_chest(chest_id: U64) -> returns value`
- `close_chest(chest_id: U64) -> returns value`
- `create_chest(creator: Address, fingerprint: BytesN<32>, token: Address, prize: I128, max_claims: U32, deadline: U64) -> returns value`
- `recipient_field(recipient: Address) -> returns value`

### UDTs Detected (3)

#### STRUCT Chest

- `claims: U32`
- `closed: Bool`
- `creator: Address`
- `deadline: U64`
- `fingerprint: BytesN<32>`
- `max_claims: U32`
- `prize: I128`
- `token: Address`

#### STRUCT Proof

- `a: BytesN<64>`
- `b: BytesN<128>`
- `c: BytesN<64>`

#### UNION DataKey

- `Verifier`
- `NextId`
- `Chest(U64)`
- `Nullifier(BytesN<32>)`

# 4. Chaos Execution

Kuyfi performs black-box fuzzing against the deployed Soroban contract using its on-chain contract specification.

| | |
|---|---|
| **Vectors executed** | 51 |
| **Broadcast transactions** | 3 |
| **Transactions with hash** | 3 |
| **Verification transactions** | 1 |

# 5. Findings

### [KYF-001] HIGH — POTENTIAL_VULN

| | |
|---|---|
| **Function** | recipient_field |
| **Attack vector** | UNAUTHORIZED_ADDR_CALL |

Details: UNAUTHORIZED_ADDR_CALL: access control bypass — call was NOT rejected on recipient_field

### Evidence

| | |
|---|---|
| **Simulation failed** | false |
| **Broadcasted** | true |
| **Transaction hash** | 063ed634cbe520f8195dc7bf6a958fece03b849941abc2f29213676066ba3c01 |
| **Ledger** | 5381009 |

**Explorer URL**
https://stellar.expert/explorer/testnet/tx/063ed634cbe520f8195dc7bf6a958fece03b849941abc2f29213676066ba3c01

### Trace Summary

| | |
|---|---|
| **Root call** | recipient_field @ bd0e57d0a80dd24268c5fc4df305b286b25995bc9d98cf83ad09b76b8970d14e |
| **Nested call count** | 0 |
| **Involved contracts** | bd0e57d0a80dd24268c5fc4df305b286b25995bc9d98cf83ad09b76b8970d14e |
| **Auth error** | false |
| **Failure location** | UNKNOWN |
| **Malformed trace** | false |

# 6. Verification

Real Testnet transactions broadcast during this audit run, provided so every claim above can be independently verified on-chain.

**recipient_field — recipient::RANDOM_ADDR_A**

| | |
|---|---|
| **Transaction hash** | 5a2ace4af0cd6517aed4f9d5c775d55d476f1474f7d7114b57eb9addf974c9c0 |
| **Ledger** | 5381007 |

**Explorer URL**
https://stellar.expert/explorer/testnet/tx/5a2ace4af0cd6517aed4f9d5c775d55d476f1474f7d7114b57eb9addf974c9c0